Lab 07: Read an HTTP Exchange

A scope-first bug-bounty learning exercise using browser tools and an authorised training page

Objective

Learn to describe an HTTP request and response clearly. This exercise builds the observation and note-taking skills used before any vulnerability claim: method, path, status code, response type, and relevant security controls.

PRACTICE BOUNDARY Use PortSwigger Web Security Academy's intended lab or a local, isolated OWASP Juice Shop instance. Do not test unrelated public websites, try other users' accounts, or run scanners for this exercise.

Step 1 - Set up a safe observation

1. Open a training page you are explicitly allowed to use and read the lab instructions first.
2. Open your browser developer tools and select the Network panel.
3. Reload the training page and select an ordinary request generated by your own browser.
4. Record the method, path, status code, content type, and whether the response was expected. Do not copy session cookies, tokens, or personal data into your notes.

Step 2 - Read status codes in context

Code family / example	Friendly explanation	Careful interpretation
200 OK	The server completed the request.	Does not prove the response was secure or appropriate.
301 / 302	The server redirects the browser.	A redirect may be expected. Read the destination within the lab scope.
401 / 403	Authentication or permission is required or denied.	Do not try to bypass it on a real system. In a lab, follow the provided instructions.
404 Not Found	The requested route or resource was not found.	A 404 is not automatically a vulnerability.

Step 3 - Make a safe observation note

Field	Example / what to record
Environment	Name of the official training lab or local app.
Request	GET /profile (training page); remove tokens and secrets.
Status	200 OK; note whether that matches the intended behaviour.

Field	Example / what to record
Response metadata	Content-Type and other relevant non-secret headers.
Expected vs observed	What did the lab say should happen, and what actually happened?
Conclusion	Observation only, a confirmed lab issue, or inconclusive. Explain why.

Step 4 - Understand common header concepts

- Secure cookie attribute: tells browsers to send the cookie only over secure HTTPS connections.
- HttpOnly cookie attribute: prevents client-side scripts from reading the cookie through standard browser APIs.
- SameSite cookie attribute: helps control when browsers attach cookies to cross-site requests.
- Content-Security-Policy: a browser-enforced policy that can reduce the impact of some content-injection problems.
- A missing or unusual header is a clue to review in context, not automatically a reportable vulnerability.

Step 5 - Finish the worksheet

Use labs/bug-bounty-http-observation-worksheet.csv. Record only the training environment and non-sensitive evidence. If you identify a possible issue, confirm that the lab expects you to test it and write down the expected behaviour, observed behaviour, minimal reproduction, impact, and a defensive fix.

Further learning

- PortSwigger Web Security Academy
- OWASP Web Security Testing Guide
- OWASP Juice Shop

STOP IF UNCLEAR If the target is not a designated training environment or written scope is unclear, stop. The exercise is about observation and reporting, not obtaining access.

A real lab for these notes

Topic: HTTP methods, status codes, headers, body, and safe observation. These pages connect the existing OpenCyberPath notes to specific provider-hosted exercises. The card label is intentionally generic; the exact task name and direct URL are listed here so you can open the right exercise instead of a whole catalogue.

Concept checkpoints

- Request: method, path, host, headers, and optional body. Response: status, headers, and content.
- HTTP 200 indicates a successful response, 302 a redirect, 401 unauthenticated, 403 forbidden, and 404 not found; application context matters.
- HTTPS encrypts transport; the browser still displays status and response metadata.
- Capture the exact timestamp and lab hostname but redact cookies and authorization headers.

HTTP in Detail *[TryHackMe]*
https://tryhackme.com/room/httpindetail
Access note: Account required; the page uses a website exercise and interactive questions. Confirm current room availability before starting.

Wireshark: The Basics *[TryHackMe]*
https://tryhackme.com/room/wiresharkthebasics
Access note: Account required; a deployable machine and practice PCAP are described on the page. Some tasks may require a paid entitlement.

ACCESS CHECK Open the exact task page and verify the current login, account tier, VM launch button, free/paid terms, and any cost notes before starting. A provider may change availability or retire a challenge.

Before you click Start

- Write down the provider's target/scope and use only the instance it creates for you.
- Keep this notebook beside the exercise. Use its original course data before trying commands on a local machine.
- Capture timestamps, filenames, row/packet IDs, and a short explanation; redact credentials, tokens, and personal data.
- If a page says retired, premium, or downloadable-only, use the alternative listed in the access note or return to the matching interactive lab above.

Commands you can explain

The placeholder hostname must be replaced only by your generated training instance. Never run verbose HTTP commands against targets outside the permitted lab scope.

First download the matching sample file(s) from the existing card when a command names one. Keep the data in a practice folder and never execute strings stored in evidence.

HTTP / PRINT RESPONSE HEADERS

```
curl -sS -D - "https://YOUR-LAB-ID.web-security-academy.net/" -o /dev/null
```

Use the generated lab ID from the active training instance, not the documentation hostname.

WINDOWS / EQUIVALENT

```
curl.exe -sS -D - "https://YOUR-LAB-ID.web-security-academy.net/" -o NUL
```

Windows uses NUL as the output sink; use only the currently launched practice host.

VERBOSE CONNECTION VIEW

```
curl -v "https://YOUR-LAB-ID.web-security-academy.net/" -o /dev/null
```

Use verbose output only in the isolated lab and never share cookies, Authorization headers, or tokens.

WIRESHARK DISPLAY FILTER

```
http || tls
```

Use filters on provider-supplied capture files. HTTPS application payloads are not normally readable without authorised decryption material.

TSHARK FIELD VIEW

```
tshark -r .\Exercise.pcapng -Y http.request -T fields -e frame.time -e ip.src -e http.request.method
-e http.host -e http.request.uri
```

Run only against the packet capture supplied by the course; replace the filename to match the lab file.

COMMAND HABIT Check the current working directory, shell, target, and expected effect before pressing Enter. Save the exact command and the output that mattered.

Guided lab run

- 1. Open the HTTP room and launch the provided website exercise.
- 2. Identify request method, hostname, path, and any query parameters.
- 3. Record the response code, content type, redirect location (if any), and security headers relevant to the learning objective.
- 4. If working with a capture, note frame number/time and distinguish HTTP from encrypted TLS traffic.
- 5. Write a plain-language observation; do not label a response as vulnerable without evidence tied to the objective.

Evidence checklist

- [ ] What exact lab instance or sample file was used?
- [ ] Which command/query and time range produced the observation?
- [ ] What is the directly observed fact, separate from your inference?
- [ ] What benign/alternative explanation could fit?
- [ ] What extra record or control would help confirm the conclusion?

Check your understanding

Q Why should a report redact cookies?

Think it through: Session cookies can grant account access; they are secrets, not harmless evidence.

Q Does a 403 response alone prove the access-control design is secure?

Think it through: No. It is one observed response in one context; test expectations must match the defined lab task.

Q What should be captured for reproducibility?

Think it through: Exact lab instance, request method/path, timestamp, status, relevant redacted headers, and response behaviour.

NOTEBOOK CLOSE-OUT Finish with: Observation / Evidence source / Why it matters / Alternative explanation / Next check / Limitation. A careful “not enough evidence yet” is a valid professional result.